

Security Audit Log Implementation

Overview

A comprehensive security audit logging system has been added to track all security-related events including login attempts, account lockouts, and unauthorized access attempts.

What Was Added

1. Database Model

File: `Models/Admin/SecurityAuditLog.cs`

- Stores security events with details
- Tracks user ID, email, IP address, user agent
- Records event type, status, and timestamp
- Includes enums for event types and statuses

2. Database Configuration

File: `Data/ApplicationDbContext.cs`

- Added `SecurityAuditLogs` DbSet
- Created indexes for efficient querying
- Configured relationships and constraints

3. Security Audit Service

Files:

- `Services/Security/ISecurityAuditService.cs` (Interface)
- `Services/Security/SecurityAuditService.cs` (Implementation)

Features:

- `LogLoginSuccessAsync()` - Logs successful logins
- `LogLoginFailureAsync()` - Logs failed login attempts
- `LogLogoutAsync()` - Logs user logouts
- `LogAccountLockoutAsync()` - Logs account lockouts
- `LogUnauthorizedAccessAsync()` - Logs unauthorized access attempts

4. Login Page Integration

File: `Areas/Identity/Pages/Account/Login.cshtml.cs`

Logging Points:

- ☒ User not found → Logs failed attempt
- ☒ No password (external login required) → Logs failed attempt

- ☒ Successful login → Logs success with IP and user agent
- ☒ Account locked out → Logs lockout event
- ☒ Invalid password → Logs failed attempt

5. SuperAdmin Security Dashboard

Files:

- `Controllers/SecurityAuditController.cs` - Controller for viewing logs
- `Views/SecurityAudit/Index.cshtml` - UI for security audit log
- `Models/Admin/SecurityAuditLogViewModels.cs` - View models

Features:

-  Statistics dashboard (total attempts, successes, failures, lockouts)
-  Advanced filtering (event type, status, email, date range)
-  Paginated log view (50 entries per page)
-  Color-coded badges for event types and statuses
-  Responsive design

6. Service Registration

File: `Program.cs`

- Registered `ISecurityAuditService` as scoped service

How to Use

1. Create Database Migration

```
dotnet ef migrations add AddSecurityAuditLog
dotnet ef database update
```

2. Access Security Audit Log

1. Login as SuperAdmin
2. Navigate to: `/SecurityAudit/Index`
3. View all security events with statistics

3. Filter Events

- **By Event Type:** LoginSuccess, LoginFailure, Logout, AccountLockout, UnauthorizedAccess
- **By Status:** Success, Failure, Warning, Critical
- **By Email:** Search for specific user
- **By Date Range:** Filter by date

Security Events Tracked

Event Type	When It's Logged	Information Captured
LoginSuccess	User logs in successfully	User ID, Email, IP, User Agent
LoginFailure	Wrong password or user not found	Email, IP, User Agent, Reason
Logout	User logs out	User ID, Email, IP
AccountLockout	Account locked after 5 failed attempts	User ID, Email, IP
UnauthorizedAccess	User tries to access forbidden page	User ID, Email, IP, Resource

Dashboard Statistics

The security audit dashboard shows:

- **Total Login Attempts** - All login attempts (success + failure)
- **Successful Logins** - Number of successful authentications
- **Failed Logins** - Number of failed authentication attempts
- **Account Lockouts** - Number of accounts locked due to failed attempts

Security Benefits

- ☑ **Threat Detection** - Identify brute force attacks and suspicious activity
- ☑ **Compliance** - Meet audit requirements for security logging
- ☑ **Incident Response** - Investigate security incidents with detailed logs
- ☑ **User Monitoring** - Track user authentication patterns
- ☑ **IP Tracking** - Identify suspicious IP addresses
- ☑ **Forensics** - Complete audit trail for security investigations

Next Steps (Optional Enhancements)

1. **Add Email Alerts** - Notify admins of suspicious activity
2. **IP Blocking** - Automatically block IPs with too many failed attempts
3. **Export Functionality** - Export logs to CSV/Excel
4. **Real-time Dashboard** - Use SignalR for live updates
5. **Geolocation** - Show login locations on a map
6. **Advanced Analytics** - Charts and graphs for security trends

Documentation Updated

The following documentation files have been updated to reflect the new security audit logging:

1. FINAL_SECURITY_DOCUMENTATION.md

- Section 6: Error Handling and Logging
- Section 8: Code Auditing and Security Testing (Added Aikido Security)
- Section 9: Security Testing Procedures

2. SIMPLE_SECURITY_DOCUMENTATION.md

- Section 8: Who Can Access What (Added Aikido monitoring)

Testing

To test the security audit log:

1. Test Failed Login:

- Try to login with wrong password
- Check security audit log for "LoginFailure" event

2. Test Successful Login:

- Login with correct credentials
- Check security audit log for "LoginSuccess" event

3. Test Account Lockout:

- Try wrong password 5 times
- Check security audit log for "AccountLockout" event

4. Test Filtering:

- Use filters to search for specific events
- Verify pagination works correctly

Security Considerations

- ☒ Only SuperAdmin can access security audit logs
- ☒ Logs are stored securely in the database
- ☒ IP addresses and user agents are captured for forensics
- ☒ All timestamps are in UTC for consistency
- ☒ Sensitive data (passwords) are never logged
- ☒ User agents are truncated to 500 characters to prevent database issues

Maintenance

Log Retention:

- Consider implementing automatic log cleanup for old entries
- Recommended: Keep logs for 90 days minimum
- Archive old logs for compliance if required

Performance:

- Indexes are created for efficient querying
 - Pagination prevents loading too many records
 - Consider partitioning table if logs grow very large
-

Implementation Date: May 2026
Status: ☒ Complete and Ready for Use